

RELATÓRIO DE

Auditoria de Segurança

unico_implantacao

Data: 02/09/2026

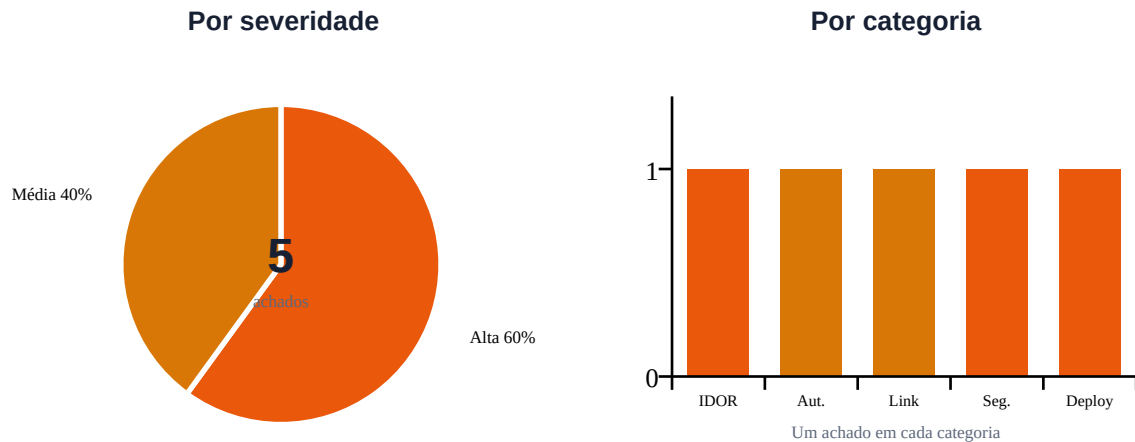
Escopo: aplicação Next.js, API Express, Prisma/PostgreSQL, Redis/BullMQ, Docker Compose, variáveis de ambiente e código de integração.

Metodologia: revisão estática das cinco categorias solicitadas. O isolamento foi mapeado ao campo `responsibleUserId` e à sessão `AdminUser`; permissões ao middleware `requireAdmin`; IDOR a todos os handlers Express; segredos aos arquivos de configuração e Compose; e XSS aos sinks de HTML/URL no React e às respostas do backend.

Classificação: três achados altos e dois médios. Não foram encontrados achados críticos ou baixos.

Resumo executivo

Foram confirmados cinco riscos acionáveis. O risco principal é a ausência de escopo por responsável nas implantações: o campo responsável existe no banco, porém não controla as consultas. Em seguida, a superfície de configuração expõe serviços e segredos a usuários locais ou rede quando o Compose for usado fora de uma máquina isolada.



Riscos centrais

A1 permite acesso cruzado entre responsáveis autenticados; A4 e A5 permitem comprometimento de infraestrutura e dados se permissões/portas estiverem no contexto errado; A2 enfraquece a trilha de auditoria; A3 prolonga o impacto de um link de onboarding vazado.

Pontos fortes verificados

- **Autenticação:** requireAuth valida assinatura JWT e recarrega o usuário ativo do banco em cada requisição (server/src/middleware/auth.middleware.ts:23-39).
- **Gestão de usuários:** todas as rotas /users aplicam requireAuth e requireAdmin antes dos handlers (server/src/modules/users/user.routes.ts:8-16); o backend não depende apenas da UI.
- **Proteção de credenciais:** senhas de serviço são cifradas e removidas das respostas da API (server/src/modules/implantations/implantation.service.ts:13-49).
- **XSS:** a única ocorrência de dangerouslySetInnerHTML está em components/ui/chart.tsx:95-112 e é alimentada apenas por chartConfig constante em components/chart-area-interactive.tsx:33-37; não há fluxo de dados controlado pelo usuário. Não há renderização de HTML/Markdown, eval/new Function ou e-mail/template HTML no backend.
- **URLs externas:** a integração aceita somente HTTPS e host terminado em .atenderbem.com (server/src/integrations/atender-bem/atender-bem.client.ts:13-30).

Achados detalhados

Severidade	Arquivo:linha	Descrição
ALTA	server/src/modules/implantations/implantation.service.ts:92-114,155-184; server/src/modules/deployments/deployment.service.ts:115-166; server/src/modules/implantations/review.service.ts:6-94	A1 - Isolamento/IDOR. O campo responsibleUserId existe no modelo, mas não é usado como filtro nas consultas nem é associado ao usuário autenticado. Qualquer MEMBER autenticado pode enumerar, ler, alterar, cancelar, revisar, aprovar ou reprocessar implantações de outros responsáveis ao conhecer o ID.
MÉDIA	server/src/modules/implantations/review.controller.ts:22-25; server/src/modules/implantations/review.schema.ts:7-9; server/src/modules/implantations/review.service.ts:76-83	A2 - Autorização. A identidade do aprovador é recebida no corpo da requisição (approvedBy) e persistida sem ser comparada à sessão. Um usuário autenticado pode registrar a aprovação em nome de qualquer pessoa.
MÉDIA	server/src/modules/onboarding/onboarding.routes.ts:7-12; server/src/modules/onboarding/onboarding.service.ts:8-18,52-109; server/prisma/schema.prisma:49-63	A3 - Link público/IDOR. O token de onboarding é a única credencial para leitura, escrita e envio do formulário público. O modelo e o serviço não têm expiração, revogação ou rotação; um link vazado permanece utilizável até a mudança de status.
ALTA	server/.env (permissões 664); .env.local (permissões 664)	A4 - Segredos. Arquivos de ambiente com credenciais reais (banco, Redis, JWT, chave de criptografia, parceiro/TOTP e seed administrativo) estão legíveis por grupo e outros usuários. Embora estejam no .gitignore e não exista Git nesta pasta, o modo atual expõe segredos a contas locais.
ALTA	docker-compose.yml:3-19	A5 - Deploy/segredos. O Compose fixa POSTGRES_PASSWORD=unico, publica PostgreSQL e Redis em todas as interfaces do host e não configura autenticação para Redis. Se iniciado em host alcançável por terceiros, há acesso remoto ao Redis e credenciais previsíveis para o banco.

A1 - Isolamento/IDOR (Alta)

Local: server/src/modules/implantations/implantation.service.ts:92-114,155-184; server/src/modules/deployments/deployment.service.ts:115-166; server/src/modules/implantations/review.service.ts:6-94

O campo responsibleUserId existe no modelo, mas não é usado como filtro nas consultas nem é associado ao usuário autenticado. Qualquer MEMBER autenticado pode enumerar, ler, alterar, cancelar, revisar, aprovar ou reprocessar implantações de outros responsáveis ao conhecer o ID.

Explorabilidade: requer uma conta MEMBER válida e o ID alvo (obtível pela própria listagem sem filtro).

A2 - Autorização (Média)

Local: server/src/modules/implantations/review.controller.ts:22-25; server/src/modules/implantations/review.schema.ts:7-9; server/src/modules/implantations/review.service.ts:76-83

A identidade do aprovador é recebida no corpo da requisição (approvedBy) e persistida sem ser comparada à sessão. Um usuário autenticado pode registrar a aprovação em nome de qualquer pessoa.

Explorabilidade: requer sessão autenticada e uma implantação em WAITING_REVIEW; basta alterar approvedBy no JSON.

A3 - Link público/IDOR (Média)

Local: server/src/modules/onboarding/onboarding.routes.ts:7-12; server/src/modules/onboarding/onboarding.service.ts:8-18,52-109; server/prisma/schema.prisma:49-63

O token de onboarding é a única credencial para leitura, escrita e envio do formulário público. O modelo e o serviço não têm expiração, revogação ou rotação; um link vazado permanece utilizável até a mudança de status.

Explorabilidade: depende de vazamento/compartilhamento indevido do link; o token UUID não é enumerável de forma prática, mas é permanente no código atual.

A4 - Segredos (Alta)

Local: server/.env (permissões 664); .env.local (permissões 664)

Arquivos de ambiente com credenciais reais (banco, Redis, JWT, chave de criptografia, parceiro/TOTP e seed administrativo) estão legíveis por grupo e outros usuários. Embora estejam no .gitignore e não exista Git nesta pasta, o modo atual expõe segredos a contas locais.

Explorabilidade: qualquer conta local que pertença ao grupo do arquivo ou tenha leitura global pode copiar os valores. Valores foram deliberadamente omitidos deste relatório.

A5 - Deploy/segredos (Alta)

Local: docker-compose.yml:3-19

O Compose fixa POSTGRES_PASSWORD=unico, publica PostgreSQL e Redis em todas as interfaces do host e não configura autenticação para Redis. Se iniciado em host alcançável por terceiros, há acesso remoto ao Redis e credenciais previsíveis para o banco.

Explorabilidade: condicionada ao Compose em execução em host alcançável pela rede; Docker publica portas sem endereço de bind explícito.

Recomendações priorizadas

P1 - Corrigir A1: instituir uma política central de escopo, com filtro por `responsibleUserId` em serviços e testes de acesso cruzado.

P1 - Corrigir A4 e rotacionar todos os valores atualmente presentes nos arquivos `.env`; restringir permissões a 600.

P1 - Corrigir A5: eliminar senha fixa, proteger Redis e restringir a exposição de portas.

P2 - Corrigir A2: fonte de verdade do aprovador deve ser `req.user.id`, nunca o corpo HTTP.

P2 - Corrigir A3: expiração, revogação e rotação de links públicos; registrar uso quando necessário.

Cobertura e limites

Foram percorridos todos os handlers da API Express: `/health`, `/auth`, `/users`, `/implantations`, `/onboarding`, `/deployments` e `/plans`. O diretório não possui `.git`; por isso não foi possível nem necessário verificar segredos em histórico. Não há CI, Helm ou Terraform no escopo. O repositório é Next.js 16.3.4/React 19 no frontend e Express/Prisma/PostgreSQL no backend.

ISSUES PARA O GITHUB

Textos prontos para copiar e colar. Os trechos de evidência não reproduzem segredos.

```
--- ISSUE 1 ---
# [Segurança] Aplicar isolamento por responsável nas implantações

Labels sugeridas: security, alta

## Problema
O campo responsibleUserId existe no modelo, mas não é usado como filtro nas consultas nem é associado ao usuário autenticado. Qualquer MEMBER autenticado pode enumerar, ler, alterar, cancelar, revisar, aprovar ou reprocessar implantações de outros responsáveis ao conhecer o ID.

## Evidência
server/src/modules/implantations/implantation.service.ts:92-114,155-184;
server/src/modules/deployments/deployment.service.ts:115-166;
server/src/modules/implantations/review.service.ts:6-94

## Impacto
Alta: acesso indevido, adulteração de auditoria ou comprometimento de dados/infraestrutura, conforme o achado.

## Sugestão de correção
Associar responsibleUserId ao req.user.id na criação e incluir o escopo em toda query de Implantation, Onboarding, DeploymentRun e DeploymentJob. ADMIN pode usar uma política explícita de acesso global.

## Critérios de aceite
- [ ] MEMBER só lista seus próprios registros.
- [ ] GET/PATCH/cancel/review/approve e deployments recusam objetos de outro responsável com 403/404.
- [ ] Testes cobrem cada rota com dois usuários.
--- FIM ISSUE 1 ---

--- ISSUE 2 ---
# [Segurança] Derivar o aprovador da sessão autenticada

Labels sugeridas: security, média

## Problema
A identidade do aprovador é recebida no corpo da requisição (approvedBy) e persistida sem ser comparada à sessão. Um usuário autenticado pode registrar a aprovação em nome de qualquer pessoa.

## Evidência
server/src/modules/implantations/review.controller.ts:22-25;
server/src/modules/implantations/review.schema.ts:7-9; server/src/modules/implantations/review.service.ts:76-83

## Impacto
Média: acesso indevido, adulteração de auditoria ou comprometimento de dados/infraestrutura, conforme o achado.

## Sugestão de correção
Remover approvedBy do schema público e chamar approve(req.params.id, req.user!.id).

## Critérios de aceite
- [ ] O corpo não aceita approvedBy.
- [ ] approvedBy gravado no snapshot coincide com req.user.id.
- [ ] Teste prova que valor enviado pelo cliente não altera a autoria.
--- FIM ISSUE 2 ---

--- ISSUE 3 ---
# [Segurança] Expirar e revogar links de onboarding

Labels sugeridas: security, média

## Problema
O token de onboarding é a única credencial para leitura, escrita e envio do formulário público. O modelo e o serviço não têm expiração, revogação ou rotação; um link vazado permanece utilizável até a mudança de status.

## Evidência
server/src/modules/onboarding/onboarding.routes.ts:7-12;
server/src/modules/onboarding/onboarding.service.ts:8-18,52-109; server/prisma/schema.prisma:49-63

## Impacto
Média: acesso indevido, adulteração de auditoria ou comprometimento de dados/infraestrutura, conforme o achado.

## Sugestão de correção
Adicionar validade e revogação/rotação ao token, comparar no serviço e permitir emissão de novo link.

## Critérios de aceite
- [ ] Token expirado retorna 401/404 e não lê nem escreve dados.
- [ ] Token revogado não funciona.
- [ ] Novo token invalida o anterior.
--- FIM ISSUE 3 ---
```

--- ISSUE 4 ---

[Segurança] Restringir leitura dos arquivos de ambiente

Labels sugeridas: security, alta

Problema

Arquivos de ambiente com credenciais reais (banco, Redis, JWT, chave de criptografia, parceiro/TOTP e seed administrativo) estão legíveis por grupo e outros usuários. Embora estejam no .gitignore e não exista Git nesta pasta, o modo atual expõe segredos a contas locais.

Evidência

server/.env (permissões 664); .env.local (permissões 664)

Impacto

Alta: acesso indevido, adulteração de auditoria ou comprometimento de dados/infraestrutura, conforme o achado.

Sugestão de correção

Mover segredos para um cofre/secret manager quando aplicável e definir permissões 600 nos arquivos locais; rotacionar os valores presentes.

Critérios de aceite

- [] Arquivos de segredo têm proprietário-only (600) ou deixam de existir no host.
- [] Valores atuais foram rotacionados.
- [] Pipeline não imprime valores de ambiente.

--- FIM ISSUE 4 ---

--- ISSUE 5 ---

[Segurança] Remover credenciais e portas abertas do Compose

Labels sugeridas: security, alta

Problema

O Compose fixa POSTGRES_PASSWORD=unico, publica PostgreSQL e Redis em todas as interfaces do host e não configura autenticação para Redis. Se iniciado em host alcançável por terceiros, há acesso remoto ao Redis e credenciais previsíveis para o banco.

Evidência

docker-compose.yml:3-19

Impacto

Alta: acesso indevido, adulteração de auditoria ou comprometimento de dados/infraestrutura, conforme o achado.

Sugestão de correção

Ler credenciais via variáveis sem default inseguro, exigir senha Redis e publicar portas apenas em 127.0.0.1 ou rede interna.

Critérios de aceite

- [] Compose não contém senha fixa.
- [] Redis exige autenticação.
- [] Portas não são expostas em interfaces públicas por padrão.

--- FIM ISSUE 5 ---